Mastara (ማስታራ) — Software Requirements Specification v3.2

Consolidated baseline · adds the 20–25 October 2026 decisions · supersedes v3.0 and v3.1

Field	Value
Product	Mastara (ማስታራ) — online-first learning app for Ethiopian university freshmen, with optional downloads for offline study
Document ID	MASTARA-SRS-001
Version	3.2 (supersedes 3.0 and 3.1)
Status	Draft for product-owner approval
Date	25 October 2026
Student app	React Native with Expo (Android first, iOS supported)
Admin portal	Next.js
Backend	NestJS (REST)
Database	PostgreSQL
Package manager	npm workspaces
Account types	STUDENT and ADMIN. Admin subtypes: Super Admin, Academic Admin, Operations Admin
Currency	ETB
App size	Under 20 MB arm64 download (hard release gate)
Normative language	MUST = mandatory · SHOULD = recommended · MAY = optional

1. Purpose and how to read this document

This is the single authoritative specification for Mastara. It keeps the v3.1 baseline and adds every instruction from the product owner between 20 and 25 October 2026. Where two instructions conflict, the later one wins. Section 3 lists each decision and what it replaces, so the product owner can overrule any reading.

Tags used in headings and tables: **[NEW]** added in v3.2, **[CHANGED]** replaces a v3.1 rule, **[UNCHANGED]** carried over from v3.1 in summary. Where a v3.1 rule is not restated here, the v3.1 text still applies until v3.3 merges the two. The v3.1 file also carried “v3.0” in its page title and footer; this version corrects that.

Priority: P0 launch-blocking, P1 launch-expected, P2 later. Requirement IDs use a partition letter (for example FR-E12).

2. What changed since v3.1

#	Change	Replaces in v3.1
C1	Three admin subtypes with a permission matrix, scopes and approval rules (4.4–4.6)	D3: “only two roles” (kept as the account type)
C2	Student IDs in the form MS0001, allocated without gaps (8.4)	No ID format defined
C3	Listings always visible, instantly and offline. Opening needs permission plus a source: online, or a downloaded copy (5.3)	D5, FR-C06, FR-C07, NFR-04, and the 23 Oct “must download first” rule
C4	One shared access function and a fixed free-access precedence (5.2)	4.6 free trial, FR-C17
C5	One paywall sheet, one wording, shown at every gate (6.6)	Lock state in 5.4
C6	Question numbers restart at 1 in every exam set or quiz chapter (8.5)	FR-G11 (one global auto-increment)
C7	CSV-only bulk import, validated by content (8.6)	Not specified

#	Change	Replaces in v3.1
C8	One pagination standard for every list (8.3)	FR-B09, FR-G25
C9	Local account hardening and first-purchase registration (6.1)	FR-A01 to A05
C10	Real API data only; mocks are development-only (10.5)	Not specified
C11	One colour source for admin and mobile, shared status tones, per-course accent (8.7)	6.11 visual system
C12	Security baseline (11)	11
C13	Refund workflow (5.5)	Not specified
C14	Performance targets for instant rendering (9)	NFR table

3. Authoritative decisions

3.1 Decisions carried over from v3.1

#	Decision	Status
D1	Stack: Expo React Native, Next.js admin, NestJS API, PostgreSQL, npm workspaces	[UNCHANGED]
D2	Release package under 20 MB, measured as the arm64 download size from the Android App Bundle	[UNCHANGED]
D3	Account types are STUDENT and ADMIN. Admin has subtypes (D20)	[CHANGED]
D4	Local-first account; nothing reaches the remote database before the first purchase (refined in D21)	[CHANGED]
D5	Online-first content with optional download (clarified in D24)	[CHANGED]

#	Decision	Status
D6	Continue Learning is removed from Home and from the specification	[UNCHANGED]
D7	Home is card-based; the COC Exam card uses the course-card style	[UNCHANGED]
D8	Material tabs are Modules, Notes, Amharic Note. Amharic Notes are their own content items; no language toggle inside content	[UNCHANGED]
D9	Screenshots and screen recording are blocked on every content screen	[UNCHANGED]
D10	Light and dark theme on every screen; brand colours unchanged	[UNCHANGED]
D11	Scroll-first reading with a bottom Next button	[UNCHANGED]
D12	Review Answer after every exam and COC, with Show / Hide descriptions	[UNCHANGED]
D13	Exam duration is set on the exam set, not on question forms	[UNCHANGED]
D14	Question forms and lists follow 8.5	[UNCHANGED]
D15	COC Exam is a standalone Home module	[UNCHANGED]
D16	GPA is out of scope	[UNCHANGED]
D17	Payment is a manual receipt screenshot verified by Admin	[UNCHANGED]
D18	Each course carries a free-trial item count set by Admin	[UNCHANGED]
D19	Build order: Question Bank first, in small sub-phases	[UNCHANGED]

3.2 New decisions

#	Decision
D20	**Admin subtypes.** Super Admin, Academic Admin and Operations Admin, each with its own permissions and scope (4.4). The account type stays ADMIN, so existing authentication is unchanged
D21	**Local account states.** LOCAL_ONLY (register, sign in and edit the profile offline; no student data is sent to the server) and REGISTERED_REMOTE (after the first purchase). Only a salted hash of the password is stored on the phone. The student re-enters the password at the first purchase so the server can create the account
D22	**Student ID.** “MS” followed by at least four digits, from MS0001, allocated inside the transaction that creates the remote student. Admin accounts live in a separate table and never consume student numbers
D23	**Catalog visibility.** Every student sees every course, chapter, exam and test in lists, with a Free, Paid or Locked badge, immediately and offline
D24	**Opening content.** Allowed only when the student has permission and a source. Online students may open content without downloading. Offline students open only what they downloaded. This supersedes the 23 Oct rule that a course must be downloaded before use
D25	**One access function** (`canOpen`) shared by the server and the app (5.2)
D26	**One paywall sheet** with fixed wording and a Purchase Course button (6.6)
D27	**Question number** restarts at 1 per exam set or quiz chapter; the global database identity is separate

#	Decision
D28	**Bulk question import accepts CSV only**, checked by file content, not by extension
D29	**Pagination standard** for every admin list (8.3)
D30	**Real data only.** All mock and dummy data is removed from production builds
D31	**One colour source.** Admin and mobile both read `packages/ui-tokens`; statuses share one tone mapping; each course carries an accent name
D32	**Active state.** The active content tab and the active sidebar child use the same colour token
D33	**Security baseline** (11)
D34	**Refunds** follow a request, approval and revocation workflow (5.5)

4. Product definition, scope and roles

4.1 Definition [UNCHANGED]

Mastara helps freshmen find materials, understand them, practise and sit exams, even on cheap phones with unreliable internet. A student sets University, Program, Semester and Stream, adds courses to My Course List, tries free items, then buys access. Learning uses modules, notes, Amharic notes, quizzes, Mid, Final and Mock exams, and a standalone COC Exam.

4.2 In scope

- Local account creation and profile setup that work offline; phone registration, device binding and release at the first purchase.
- A stream-filtered catalog (Natural, Social, Common) that is cached on the phone and visible offline **[NEW]**.
- Course tabs Material, Tests, Exams; a standalone COC Exam on Home.
- Online delivery, optional download, delete downloads, review of answers with Show / Hide.

- Bundles, single courses, extra courses, the Full Freshman package, receipt payment, Admin verification, automatic expiry, refunds **[NEW]**.
- Admin portal: catalog, content, Scan to PDF, Questions, Products and Pricing, payments, entitlements, devices, notifications, support, audit, reports, and admin account management **[NEW]**.
- Screen-capture blocking, dark and light themes, a colourful icon system.

4.3 Out of scope

GPA calculation; Continue Learning; automated payment gateways and automated refund payout; live remote proctoring; AI tutor and recommendations; iOS store billing.

4.4 Account types and admin subtypes [CHANGED]

Role	Who	Responsibilities
STUDENT	Learner	Create a local account, choose scope, use free items, register a phone and buy access, learn, sit exams, review answers, download or delete content, upload payment proof, release own device
ADMIN: Super Admin	Platform owner or trusted system administrator (two or three people at most)	Manage admin accounts, roles, permissions and scopes; create and delete universities, departments, programs, semesters and courses; control content, tests, COC and publishing; manage products, prices and system configuration; access audit logs, reports and security settings; approve refunds

Role	Who	Responsibilities
ADMIN: Academic Admin	Academic coordinators, teachers, content managers	Edit course details, chapters and order within the assigned scope; create and edit notes, materials, questions, Quiz 1, 2, 3 and COC exams; use Scan to PDF; submit content for review; set chapter-level free flags within scope; send course-scoped announcements
ADMIN: Operations Admin	Student support and finance staff	Student account support and access issues; review purchases, payments and receipts; handle support requests; request refunds; view operational reports and relevant student activity; release device bindings and make limited access grants within their permissions

The client never sends a role. A forged role is ignored and logged.

4.5 Permission matrix [NEW]

Full = create, read, update, delete. Scoped = only inside the assigned university, program or course. View = read only. A dash means no access.

Area	Super Admin	Academic Admin	Operations Admin
Admin accounts, roles, scopes	Full	—	—
Universities, programs, semesters, courses (create, delete)	Full	— (edit within scope)	View
Chapters, notes, modules, Amharic notes, Scan to PDF	Full	Scoped	—
Questions, Quiz 1–3, Mid, Final, Mock, COC	Full	Scoped	—

Area	Super Admin	Academic Admin	Operations Admin
Submit for review	Full	Scoped	—
Publish	Full	Reviewer only if granted, never own work	—
Chapter free flag	Full	Scoped	—
Course Free Access, free-trial count	Full	—	—
Products, prices, durations	Full	—	View
Payments and receipts	Full	—	Full
Refunds	Approve	—	Request
Students (profile, status)	Full	—	Full, minimal fields
Device release, manual access grant	Full	—	Limited, reason required
Support tickets	Full	—	Full
Announcements	Full	Course-scoped	Payment and system notices
Reports	Full	Academic only	Operational only
Audit log, security settings	Full	—	Own actions only

4.6 Admin rules [NEW]

- **Server authority.** Permissions and scopes are checked on every admin request, and list queries are filtered by scope. Hiding a button in the portal is never the only control.
- **Maker-checker.** Content moves Draft → In Review → Published. The publisher MUST be a different person from the author.
- **Revenue controls.** Prices, durations, products, course Free Access and free-trial counts are Super Admin only.

- **Reasons and limits.** Manual access grants, device releases, refunds and price changes require a reason and are audited. Refunds and access grants above an Admin-set limit need Super Admin approval.
- **Authentication.** Two-factor authentication (TOTP) is mandatory for Super Admin and Operations Admin. Admin sessions last at most 12 hours.
- **Data minimisation.** Academic Admin never sees payments, receipts or student personal data. Receipt and phone-number views are logged.
- **Safety.** The last active Super Admin cannot be deleted, deactivated or demoted, and no admin can remove their own account.

4.7 Server authorization rule

ALLOW = authenticated + role permission + scope + resource state + business rule. Paid content opens only when the student is authenticated, the device matches, the entitlement is active for the course, and the content status is PUBLISHED. Free items open under the rule in 5.2.

5. Commerce and access model

Every number is Admin-managed configuration. Defaults come from the brief.

5.1 Products and pricing [UNCHANGED]

Product	Default price	Rule
Semester Bundle	200 ETB	7–10 courses of one semester and stream (range Admin-configurable)
Extra Course	100 ETB first, then 50 ETB	Courses beyond the bundle maximum use the Admin tiered schedule
Single Course	Admin-defined	May be bought before any bundle
Full Freshman Package	350 ETB per stream	All stream courses plus Common courses, both semesters, with COC and exams
Both Streams	Admin-defined (default 2 × 350)	Natural, Social or both in one order

Rules PR-1 to PR-7 from v3.1 still apply: bundle range checked on client and server, extras priced in the summary, price computed on the server, a Full package covers owned courses, no re-buy while actively entitled until the renewal window, price changes apply to new orders only, singles are not credited to a later bundle unless configured.

5.2 Free access and the single access function [CHANGED]

The app and the server MUST use the same function, `canOpen(student, item)`, with this fixed order:

1. Item inactive, unpublished or deleted → **unavailable**.
2. Student has an active entitlement for the item's course → **open**.
3. The course has Free Access → **open**.
4. The item is free at item level (chapter Free flag, the first N free-trial items of the course, a free exam set, or a COC sample set) → **open**.
5. Otherwise → **locked**.

A free item never creates an entitlement. Free items are served as public, rate-limited, watermarked assets keyed to an anonymous install ID. Admin can still flag individual items free or locked.

5.3 Visibility and opening content [NEW]

Visibility. Every student sees all listings: courses in scope, chapters, exam sets, test sets and COC sets. Each row shows a badge (Free, Paid with a lock, Downloaded, or Not available offline). Listings come from the catalog stored on the phone and appear without a loading state.

Opening. A student opens an item only if `canOpen` allows it **and** a source exists:

Student	Network	Downloaded	Result
Any	Any	n/a	List and badges appear instantly
Free item	Online	No	Opens from the server
Free item	Offline	Yes	Opens from the local copy
Free item	Offline	No	Message: offline, download this item while online

Student	Network	Downloaded	Result
Paid item, student has paid	Online	No	Opens from the server
Paid item, student has paid	Offline	Yes	Opens until the entitlement expires
Paid item, student has paid	Offline	No	Same offline message
Paid item, student has not paid	Any	Any	Paywall sheet (6.6)
Paid item, entitlement expired	Any	Yes	Locked; the downloaded copy stops opening

Content fetched online but not downloaded is held in memory only and is not available offline. The catalog never contains content bodies, so listing titles to unpaid students does not expose paid material.

5.4 Duration and expiry [UNCHANGED]

Admin sets duration_days per product. Approval creates entitlements with starts_at and expires_at. The server is authoritative; when expires_at passes, protected content locks and downloaded copies stop opening. Device clock changes MUST NOT extend access. The app verifies a server-signed entitlement token offline and keeps a last-seen server time so a clock rollback cannot extend access **[NEW]**.

5.5 Refunds [NEW]

States: REQUESTED → APPROVED or REJECTED → PAID_OUT → ENTITLEMENT_REVOKED. Operations Admin creates the request with a reason; Super Admin approves or rejects; payout is manual outside the system and recorded with a reference. Approval revokes the entitlements of the refunded order. Every step is audited. The refund policy (who is eligible and for how long) is an open question (Q12).

6. Student experience

6.1 Local account, first purchase and sign-in [CHANGED]

State	Meaning	Server data
LOCAL_ONLY	Student registered on this phone. Registration, sign-in and profile edits work offline	None. No student data leaves the phone
REGISTERED_REMOTE	The student made the first purchase and the server account exists	Student, device binding, entitlements, progress

Requirements:

- **FR-A01 (P0)** Create a local account (name, password or PIN, phone or email as the sign-in identifier) with no network. Works in airplane mode.
- **FR-A02 (P0)** The password is stored only as a salted, iterated hash in secure storage, compared in constant time. The plain password is never stored.
- **FR-A03 (P0)** Failed sign-ins are limited with growing delays (after 5 failures, 30 seconds, doubling up to 15 minutes).
- **FR-A04 (P0)** Accounts saved by older versions with a plain password are upgraded to a hash on the next successful sign-in and the plain value is erased.
- **FR-A05 (P0)** Offline sign-in succeeds only with the matching password. Knowing the identifier alone never opens the app. The first sign-in on a new phone needs internet.
- **FR-A06 (P0)** Before the first purchase the app sends no student data to the server. A network spy test proves it.
- **FR-A07 (P0)** At the first purchase the student verifies a phone number and **re-enters the password** so the server can create the account. The password travels over TLS and the server hashes it. The local hash is never uploaded or used as the server credential.
- **FR-A08 (P0)** Each local account has a random localAccountId (UUID). It is the idempotency key of the first sync, so repeating the call changes nothing.
- **FR-A09 (P0)** If the phone number already belongs to another account (409 PHONE_ALREADY_REGISTERED), the app shows a screen with Sign in and Contact Admin, never a dead end.
- **FR-A10 (P0)** Mock sign-in code is absent from release builds.

- **FR-A11 (P1)** A notice at account creation and in Profile warns that uninstalling before the first purchase erases local progress.

The server MUST NOT expose a registration route that creates a student before purchase. Device binding, one-device rules and release (v3.1 6.9) are unchanged and begin at the first purchase.

6.2 Primary workflow

Install → Splash → Create account (local) → Profile Setup → Home. A returning student with a complete profile goes straight to Home. Select Courses appears only on first use. Profile Setup needs universities, programs, semesters and courses even when the phone has never been online, so the app bundles a seed catalog (6.4).

6.3 Home and navigation [UNCHANGED]

Home has five cards: Courses, COC Exam, Learning Status, Payment Alerts, Store Status. Bottom navigation: Home, Course, Progress, Profile. The Course screen has a search field and the tabs All, Ongoing, Completed. Course tabs are Material, Tests, Exams; Material has Modules, Notes, Amharic Note; Tests has Quiz 1–3; Exams has Mid, Final, Mock. The COC Exam opens only from its Home card.

6.4 Catalog on the phone [NEW]

The catalog is the metadata of everything a student can see. It holds no content bodies.

- **Contents.** Universities, programs, semesters, courses (stream, access flags, accent), chapters (title, order, type, free flag, version), exam sets, quiz sets and COC sets (name, year, question count, duration, access).
- **Scope.** The student's university, program, semester and stream plus Common courses. Changing scope loads the new scope.
- **Storage.** SQLite tables for catalog items and sync state, loaded into memory during the splash screen so the first list draws without a loading state.
- **Seed.** A catalog seed is generated at release time and bundled (target at most 150 KB compressed), so the first launch works offline.
- **Sync.** The app requests only changes since its last version. The response carries new and changed items and deletions, with an ETag and compression, and needs no login. Triggers: profile saved, app returns to the foreground, connection restored (debounced), pull to refresh. Retries use exponential backoff with jitter. There is no fixed-interval polling.

- **Versions.** The server bumps an item's version when it is published, edited, deactivated, or changes between Free and Paid.
- **Never blocking.** Screens render from local data and update when newer data arrives.

6.5 Reading, quizzes and exams [UNCHANGED, with additions]

Scroll-first pages with a bottom Next button, Review Answer with Show / Hide, a monotonic exam timer, and screenshot blocking all remain as in v3.1 (6.4–6.6). Additions: an item opened online is held in memory only; the app MAY prefetch the next chapter into memory while the student reads; offline opening follows 5.3.

6.6 Paywall and offline messages [NEW]

One component, LockedContentSheet, appears at every gate: chapter for Modules, Notes and Amharic Notes; Mid, Final and Mock for Exams; chapter for Tests; exam for COC.

Case	English	Amharic (to be reviewed by a native editor)
Title	Locked Content	የተቆለፈ ይዘት
Message	You cannot access this content.	ይህን ይዘት መከፈት አይችሉም።
Button	Purchase Course	ኮርሱን ይግዙ
Offline, not downloaded	You're offline. Download this item while online to read it offline.	እኑን ከኢንተርኔት ውጥ ነዎት። ከተገናኘሱ በኛነት ይውረዱ።

The Purchase Course button opens the Store with the course preselected. The server returns 403 CONTENT_LOCKED with a reason, and the app maps it to this sheet. Each row also shows the access state before the student taps (5.3).

6.7 Downloads [CHANGED]

- **States:** not downloaded, downloading (with progress), downloaded, update available, failed.
- **Button:** Download or Delete according to the state. Delete removes the files and the database rows and the button changes back to Download.
- **Rules:** downloads resume after interruption, a low-storage warning appears before a download, deleting a course while one of its items is open is handled, and an update replaces the download in one step so the old copy stays readable if it fails.

- **Keys:** free items use a device key kept in secure storage. Paid items use a key issued after entitlement and carry a license expiry that the app checks on open. Expiry, release or revocation makes paid downloads unreadable.
- **Optional.** A student MAY use any permitted item online without downloading it (D24).

6.8 Store, payment, device, profile [UNCHANGED]

The store flow, receipt rules (compression under 300 KB, unique reference), device lock and release, Profile and My Course List behave as in v3.1 (6.7–6.10).

7. Information architecture and navigation

Hierarchy: University → Program → Semester → Course (stream) → Material | Tests | Exams. The COC Exam sits beside this tree and is reached from Home.

Admin sidebar order stays: Dashboard · Students · Courses · Content (Material: Modules, Notes, Amharic Notes; Tests: Quiz 1, 2, 3) · Scan to PDF · Questions (Mid, Final, Mock, COC) · Payments · Pricing · Support · Announcements · Reports · Audit Log. **New:** Admins and Roles (Super Admin only), and Refunds as a tab of Payments. The sidebar and every action show only what the signed-in role may use (4.5), and a forbidden route shows a 403 page.

Access states on every student card: Available, Free, Locked, Pending verification, Expiring, Expired, Downloaded, Not available offline.

8. Admin portal rules

8.1 Shell [UNCHANGED]

Dark navy sidebar, top bar with global search, page header with a back link and a Preview as student button, pill tabs in the same order as the sidebar, white cards, and a bottom action bar (Add, Reset, Save Draft, Publish) on every authoring form.

8.2 Content page: list first [CHANGED]

The admin chooses a tab (Modules, Notes, Amharic Notes, Quiz 1, Quiz 2, Quiz 3). The page shows a table of existing items with filters, pagination, Edit, Delete and the Active toggle. Pressing Add opens the form. The **test set form** has: Program, Semester, Stream,

Course, Test Set ID, Time Allowed and Access / Permission. Time Allowed is optional on quiz sets (empty means untimed); see Q13.

8.3 Pagination [NEW]

- **FR-G40 (P0)** Every list endpoint accepts page (at least 1) and pageSize (1–100, default 10) and returns items, page, pageSize, total and totalPages.
- **FR-G41 (P0)** Sorting always ends with a unique tiebreaker (the row id), so rows do not repeat or vanish between pages.
- **FR-G42 (P0)** Applies to students, courses, universities, programs, semesters, content, questions, exam sets, payments, products, devices, entitlements, audit, support and scan jobs.
- **FR-G43 (P0)** One shared admin table component keeps the page in the URL, returns to page 1 when a filter changes, steps back one page if a delete empties the current page, and shows the total count.
- **FR-G44 (P1)** Large exports use a dedicated export endpoint, not a bigger page size.

8.4 Student IDs [NEW]

- **FR-G45 (P0)** Student ID format: MS plus at least four digits (MS0001, MS0002 … MS9999, then MS10000).
- **FR-G46 (P0)** The number comes from a counters table. The update that increases the counter runs in the same transaction that creates the student, so a rollback also rolls back the counter and no gaps appear.
- **FR-G47 (P0)** Admin accounts are stored separately and never consume student numbers.
- **FR-G48 (P0)** The ID is shown first in the Students list and profile. A local-only student has no ID yet.

8.5 Question forms and numbering [CHANGED]

Field layouts, question types, the Build set dialog, status names and removed fields stay as in v3.1 (7.4, 7.5). Numbering changes:

- **FR-G11 (P0)** The question number restarts at 1 in every exam set or quiz chapter. It is a whole number of at least 1, set automatically as the next free number. An admin MAY change it to an unused whole number in the same set. The server validates it.

- **FR-G12 (P0)** The global database identity is a separate field and is never shown as the question number.
- **FR-G13 (P0)** Numbers are allocated in a transaction with a counter on the set, so concurrent creates never duplicate. Existing data is backfilled in creation order.
- **FR-G14 (P1)** When a question is deleted, later numbers are renumbered so students see an unbroken order (confirm in Q7).

8.6 Bulk question import [NEW]

- **FR-G50 (P0)** Only CSV is accepted. The server checks the content, not the extension or MIME type. Content beginning with %PDF or PK (zip, xlsx) is rejected.
- **FR-G51 (P0)** The file MUST be UTF-8. A byte order mark is handled, so Amharic text is not corrupted.
- **FR-G52 (P0)** The header is validated against a downloadable template, and every row is validated (type, options, correct answer).
- **FR-G53 (P0)** The import offers a dry run, a downloadable error report and an atomic commit.
- **FR-G54 (P0)** Cells starting with =, +, - or @ are neutralised to prevent formula injection. Size and row limits apply, and every import writes an audit entry.
- **FR-G55 (P1)** Tests cover Amharic text and LaTeX with commas and quotes.

8.7 Design consistency between admin and mobile [NEW]

- **One source.** Both apps read colours, spacing, radius and type from `packages/ui-tokens`. No screen types a hex value. A lint rule and a CI check reject hardcoded colours.
- **Brand palette.** Four brand colours: primary blue, ink, white and danger red. Everything else is a derived tint or a named semantic token (success, warning, text-muted, border, surface-subtle, primary-strong for hover and pressed).
- **Status tones.** One shared function maps a status to a tone, used by admin badges and mobile chips: Published, Approved, Active, Downloaded → success; Pending, Expiring → warning; Rejected, Expired, Failed → danger; Draft, Inactive, Offline → neutral; Free → primary; Locked → neutral with a lock icon.
- **Course accent.** Each course stores an accent name (one of the eight accent names) and an icon, chosen in the admin course form and read by the app. The app falls back to a colour derived from the course id when none is set.

- **Active state.** The active content tab and the active sidebar child share one colour token (D32).
- **Themes.** The admin portal gets the same light and dark themes as the app, with a toggle in the Admin menu.
- **Contrast.** Text and its background meet 4.5:1. The subtle grey is for icons and disabled states only.

8.8 Admin management (Super Admin) [NEW]

A screen to create admins, set the subtype, assign scopes (university, program or course), deactivate, reset a password, and require two-factor authentication. It enforces the last-Super-Admin rule (4.6). Every change is audited with the actor's role and scope.

9. Non-functional requirements [CHANGED]

Requirements NFR-01 to NFR-13 from v3.1 stand (size, memory, local write, security, localization, fonts, accessibility, storage, observability, data cost, availability, theming). These change or are new:

ID	Area	Requirement	Acceptance
NFR-04	Online-first	Listings come from the local catalog. Item bodies load online or from a download	Airplane-mode test per row of 5.3
NFR-14	Startup	Cold start under 3 seconds on the 2 GB reference phone, release build	Measured on a budget Android phone
NFR-15	Instant lists	Catalog lists draw from local data in under 300 ms with no loading state	Timer test; zero network requests while a list renders
NFR-16	Online open	An item opened online is readable within 2 seconds at the 95th percentile on a typical mobile connection	Throttled-network test
NFR-17	Battery and data	No fixed-interval polling. Sync is event-driven with backoff and jitter	Code audit; network trace

ID	Area	Requirement	Acceptance
NFR-18	Math rendering	Formulas must not create one WebView per paragraph. Use one shared renderer per page or math pre-rendered at publish time	Memory under 120 MB on a 2 GB phone with a 30-formula chapter
NFR-19	Pagination	Every admin list responds in under 500 ms at the 95th percentile with 10,000 rows	Load test
NFR-20	Consistency	No hardcoded colours in either app; contrast at least 4.5:1 in both themes	Lint rule and contrast test in CI

10. Technical architecture, data and API

10.1 Layers [UNCHANGED]

Student app (Expo, TypeScript, encrypted SQLite), admin portal (Next.js), API (NestJS, JWT, validation, rate limiting), PostgreSQL, S3-compatible object storage, optional Redis, Expo push. The server is the authority for device binding, entitlement, price and final exam acceptance.

10.2 Backend modules added

PermissionsModule (admin roles, scopes, guards), CatalogSnapshotModule (versioned catalog changes), CounterModule (gapless student numbers and set counters), RefundModule, plus the v3.1 modules.

10.3 Data model changes

Entity	Change
admin_user	New table: id, name, email (unique), password_hash, admin_role (SUPER_ADMIN, ACADEMIC_ADMIN, OPERATIONS_ADMIN), totp_secret, is_active, last_login_at. Existing admin rows move here from student

Entity	Change
admin_scope	admin_id, and one of university_id, program_id or course_id
counters	key (primary), value. Student numbers and per-set question numbers use it inside the creating transaction
student	Student number from counters; local_account_id (UUID, unique) as idempotency key. No admin rows
question	display_number, unique per exam set or quiz chapter. The global identity stays separate
content, exam_set	status adds IN_REVIEW; authored_by, reviewed_by; version and deleted_at (a deletion marker for catalog sync)
course	accent (one of the eight accent names), icon, free_access (boolean), replacing the unused hex colour column
refund	order_id, status, reason, requested_by, approved_by, payout_reference, amount
audit_log	actor_role and scope added; denied requests on sensitive routes are logged

10.4 API changes

- `GET /catalog/snapshot?scope=&since=` : public, versioned changes with ETag.
- `GET /entitlements/token` : server-signed entitlement token the app verifies offline.
- `/admin/admins` , `/admin/refunds` , `/admin/students/:id/devices` : new admin routes, each guarded by a permission.
- Every list returns the pagination envelope (8.3).
- New error codes: 403 PERMISSION_DENIED, 403 OUT_OF_SCOPE, 422 CSV_INVALID. Existing codes (CONTENT_LOCKED, ENTITLEMENT_EXPIRED, DEVICE_MISMATCH_LOCKED, TRANSACTION_REFERENCE_DUPLICATE, PHONE_ALREADY_REGISTERED) are unchanged.

10.5 Real data only [NEW]

Production builds of the admin portal and the app contain no mock data and no mock branches. Development mocks, if needed, run outside app code (for example MSW or Prism against the shared contracts). A missing API base URL stops the admin portal with a clear error. CI fails the build if a production bundle contains a mocks path. Parity tests create a course in admin and assert it appears for students, and that marking it inactive removes it.

10.6 Sync [CHANGED]

The outbox flushes only after phone registration. Catalog sync is separate and always allowed (6.4). The conflict matrix in v3.1 (12.5) is unchanged.

11. Security, privacy and content protection [CHANGED]

Control	Requirement
Secrets	The token-signing secret has at least 32 characters and no default value. The API refuses to start with missing or weak configuration. No secrets, uploads or build output are committed. Secret scanning runs on commit and in CI. Any secret that was ever committed is rotated
Cross-origin	The API allows only origins listed in configuration. Other origins are rejected
Rate limits	Enforced on every route (per user when signed in, otherwise per client). Sign-in and registration routes allow 5 attempts per minute per client and identifier. Payment and sync routes have their own limits
Admin sign-in	Password policy, two-factor authentication for Super Admin and Operations Admin, throttling per account and per client, 12-hour sessions, audit entries for sign-ins. Cookie-based sessions use HttpOnly, Secure and SameSite, with a CSRF header on mutations

Control	Requirement
Built-in credentials	The API never accepts a built-in or fallback password. Seed passwords come from configuration, with a minimum length, and are required in production
Student passwords	Hashed on the server. On the phone only a salted hash is stored (6.1)
Receipts	Private storage with signed URLs, real file type check, 300 KB limit, EXIF removed, access logged, retention policy defined
Personal data	Privacy policy, a data-deletion process and a defined retention period before launch
Content protection	Unchanged: screen capture blocking, watermark, signed short-lived URLs, no export
Audit	Role changes, scope changes, publishing, price and duration changes, device releases, access grants, refunds, sign-ins and denied requests on sensitive routes

12. Functional requirements added or changed

ID	P	Requirement	Acceptance
FR-A01–A11	P0	Local account and first-purchase registration (6.1)	Zero student requests before purchase; sign-in with only the identifier fails
FR-C20	P0	The catalog is stored on the phone and listings are visible offline and instantly (6.4)	Airplane-mode list test; zero network requests while rendering
FR-C21	P0	One `canOpen` function used by app and server (5.2)	Unit tests for every combination
FR-C22	P0	Online students open permitted items without downloading (5.3)	Open with the file system empty

ID	P	Requirement	Acceptance
FR-C23	P0	Offline students open only downloaded permitted items	Offline message for the rest
FR-C24	P0	LockedContentSheet at every gate with Purchase Course (6.6)	Seen at all four gates
FR-C25	P0	Download states and Download / Delete button (6.7)	Delete returns the button to Download
FR-G11–G14	P0	Question numbers per set or chapter (8.5)	Restarts at 1; concurrent creates stay unique
FR-G40–G44	P0	Pagination standard (8.3)	Every list pages correctly under filters
FR-G45–G48	P0	Student IDs MS0001 with no gaps (8.4)	50 concurrent registrations; a forced failure leaves no gap
FR-G50–G55	P0	CSV-only validated import (8.6)	A PDF renamed .csv is rejected
FR-G60	P0	Three admin subtypes and the permission matrix (4.4, 4.5)	Every route tested as every role
FR-G61	P0	Scope enforced in services and list queries	An Academic Admin cannot read or edit an out-of-scope course
FR-G62	P0	Maker–checker publishing (4.6)	A user cannot publish their own work
FR-G63	P0	Admin management screen and last-Super-Admin rule (8.8)	Last Super Admin cannot be removed
FR-G64	P1	Refund workflow (5.5)	Approval revokes the entitlement; every step audited
FR-G65	P0	One colour source, shared status tones, per-course accent, admin dark theme (8.7)	Zero hardcoded colours; contrast test passes
FR-G66	P0	No mock code in production bundles (10.5)	CI bundle check

13. Quality assurance and release gates

Gates from v3.1 stand. These are added:

Gate	Pass condition
Offline account	Register, sign in and edit the profile in airplane mode; a network spy shows no student data requests; sign-in with only the identifier fails
Catalog offline	With no connection, every list shows all items with the right badges
Access matrix	Every row of 5.3 behaves as written; an expired entitlement stops downloaded paid items
Paywall	The sheet appears at the Materials, Exams, Tests and COC gates, and its button opens the Store with the course preselected
Pagination	Every list pages correctly under filters; a delete that empties a page steps back
CSV import	A PDF or xlsx renamed .csv is rejected; Amharic text and LaTeX with commas and quotes import correctly; a dry run changes nothing
Student IDs	50 concurrent registrations give unique, gapless IDs; a forced insert failure leaves no gap
Question numbers	Numbers restart at 1 per set; concurrent creates never duplicate
Permissions	A test calls every admin route as each role and expects the right allow or deny; scope tests pass
Security	The API exits without a strong secret; an unlisted origin is rejected; a secret scan of a fresh clone is clean; no mock code is in the bundle
Performance	Cold start and list timing meet NFR-14 and NFR-15 on the reference phone
Consistency	Zero hardcoded colours; the active tab and sidebar child share one colour

Tools: Playwright for admin end-to-end tests; Maestro or Detox on a real budget Android phone for the app; k6 for payment, sync and paginated-list load; a secret scanner in the commit hook and in CI.

14. Risks and edge cases (new or changed)

ID	Risk	Mitigation
R15	A free item becomes paid while a copy is downloaded	The next sync flips the badge; the copy stays on disk but does not open until the student buys
R16	The catalog is stale after a long time offline	Show a last-updated time; versions make the next sync small
R17	Two phones register the same phone number offline	409 at first purchase leads to the Sign in / Contact Admin screen
R18	A Super Admin account is compromised	Two-factor authentication, short sessions, few accounts, audited actions, the last-admin rule
R19	Receipt images or student data leak	Private storage, signed URLs, minimal fields per role, access logging
R20	The bundled seed catalog and tokens push the app over 20 MB	Seed capped at about 150 KB compressed; the size gate in CI
R21	Many formula WebViews slow the app or exhaust memory	NFR-18
R22	Manual payment review becomes a backlog	Review time target, queue age on the dashboard, a plan for an automated provider

15. Implementation and verification roadmap

The product owner reports that the earlier remediation roadmap (security, pagination, replacing mocks, numbering and access, CI) is complete. Before new work, re-verify it against the gates in section 13, because this specification changes several of its rules.

Phase	Scope	Exit criteria
V	Verify the earlier work against section 13	Gate list green or gaps recorded
1	Roles and permissions: admin_user, admin_scope, permission guard, scopes, admin management screen, two-factor authentication	FR-G60 to G63 pass; the permission matrix test is green
2	Catalog on the phone and the access function: snapshot endpoint, local tables, seed, `canOpen`, paywall sheet, offline messages	FR-C20 to C25 pass; the access matrix test is green
3	Student IDs, question numbers, CSV import, pagination fixes	FR-G11 to G14, G40 to G55 pass
4	Design tokens, status tones, course accent, admin dark theme	FR-G65 passes; zero hardcoded colours
5	Refunds, content review workflow, admin audit improvements	FR-G62, G64 pass
6	Performance work and a pilot at one university	NFR-14 to NFR-18 met; pilot gates pass

16. Open questions for the product owner

Q1–Q6 and Q8–Q10 from v3.1 keep their stated assumptions. New or revised:

#	Question	Assumption used
Q7	When a question is deleted, renumber the rest or keep the gap?	Renumber
Q11	How many Super Admins, and above what amount do refunds and access grants need Super Admin approval?	Two to three accounts; limit set by Super Admin
Q12	Refund policy: who is eligible, for how long, full or partial?	Not defined; the workflow is built, the policy is configurable

#	Question	Assumption used
Q13	Do quiz sets carry Time Allowed? v3.1 said no; the 20 October form lists it	Optional on quiz sets; empty means untimed
Q14	The 22 October message says to replace the Free Content widget on the student page. Replace it with what, and on which page (admin Students page or the app)?	Not decided; needs a design
Q15	May a senior Academic Admin publish, or only a Super Admin?	Super Admin, with an optional reviewer grant
Q16	Are Academic Admin scopes assigned at university, program or course level?	Any of the three
Q17	May unpaid students download free items for offline use?	Yes
Q18	Is the Amharic wording in 6.6 acceptable?	Needs native review
Q19	Which universities and programs go in the bundled seed catalog?	All published at release time
Q20	Which identifier signs a local account in: phone, email or both?	Either, since phone verification happens only at purchase

Appendix A. Glossary additions

Term	Definition
LOCAL_ONLY	Account that exists only on the phone before the first purchase
REGISTERED_REMOTE	Account that also exists on the server after the first purchase
Catalog	Metadata of everything a student can see (titles, order, access flags, versions), with no content bodies

Term	Definition
Seed catalog	Catalog bundled with the app so the first launch works offline
canOpen	The single function that decides whether a student may open an item
Scope	The universities, programs or courses an Academic Admin may manage
Maker–checker	A rule that the person who publishes content is not the person who wrote it
Admin subtype	Super Admin, Academic Admin or Operations Admin

Appendix B. Final acceptance checklist

- Package under 20 MB; memory under 120 MB on a 2 GB phone.
- Local account works offline; nothing is sent to the server before the first purchase.
- Every list is visible instantly and offline; unpaid students open only free items; online students open permitted items without downloading; offline students open only downloads.
- One paywall sheet at every gate with Purchase Course.
- Three admin subtypes with enforced permissions and scopes; maker–checker publishing; two-factor authentication for money roles.
- Student IDs from MS0001 without gaps; question numbers restart per set; CSV-only validated import; pagination on every list.
- One colour source for admin and mobile; shared status tones; admin dark theme.
- No mock code in production; the API refuses to start without a strong secret; secret scan clean.
- Refund workflow, receipt privacy and a data-deletion process in place before launch.
- Light and dark theme on every screen; no GPA; no Continue Learning.